柒、電腦作業與資訊提供：CC-20000

一、風險評鑑與管理：CC-21000

編　號	作業項目	作業程序及控制重點	依據資料
CC-21000(網際網路下單期貨商適用)	風險評鑑與管理	(一)應鑑別公司適用資訊安全風險範圍內之所有資訊資產以及其擁有者。 (二)應確定公司各作業可接受之資訊安全風險等級。 (三)公司應至少每年進行一次資訊安全風險評鑑，並留存相關紀錄，營運相關的重大風險與控管措施議題(包括新產品、新興技術和資訊系統的風險)應納入風險評估範圍，以確保公司政策、程序和控管措施之有效性。 (四)應評估核心系統可容忍中斷時間、復原時間目標(RTO)、資料復原點目標(RPO)，並依經紀業務規模市占率暨自然人客戶數比率分級，訂定核心系統可容忍中斷時間。	一、法令規章： (一)「建立期貨商資通安全檢查機制」

二、資訊安全政策：CC-22000

編　號	作業項目	作業程序及控制重點	依據資料
CC-22000	資訊安全政策	(一)公司應依據相關法令規定及公司業務需求，訂定資訊安全政策、資訊作業之安全水準。 (二)制訂資訊安全政策，應包括下列事項： 1.資訊安全之定義、資訊安全之目標及資訊安全之範圍等。 2.資訊安全政策之解釋及說明，資訊安全之原則、標準以及員工應遵守之相關規定。 3.推行資訊安全工作之組織、權責及分工。 4.發生資訊安全事件之緊急通報程序、處理流程、相關規定及說明。 (三)公司所訂定之資訊安全政策，應經管理階層核准，並應正式發布要求所有員工共同遵守，並轉知與公司連線作業之公私機關(構)、提供資訊服務之廠商共同遵行。 (四)公司訂定之資訊安全政策，應至少每年評估乙次，以反映法令規章、技術及業務等最新發展現況，確保資訊安全實務作業之有效性，前開之評估工作應留存相關紀錄。 (五)資訊安全政策之評估，應以獨立及客觀之方式進行，並委由內部或委託外部專業機構辦理。 (六)公司每年應將前一年度資訊安全整體執行情形，由資訊安全長或負責資訊安全之最高主管與董事長、總經理、稽核主管聯名出具「證券暨期貨市場各服務事業建立內部控制制度處理準則」第二十四條規定之內部控制制度聲明書，於會計年度終了後三個月內提報董事會通過，並將該聲明書內容揭露於主管機關指定之申報網站。 (七)公司應參考「建立期貨商資通安全檢查機制-分級防護應辦事項附表」辦理資訊安全分級防護應辦事項。 (八)公司應依其所屬資安分級辦理核心系統導入資訊安全管理系統，並通過公正第三方之驗證，且持續維持驗證有效性。	一、法令規章： (一)證券暨期貨市場各服務事業建立內部控制制度處理準則第 10 條 (二)「建立期貨商資通安全檢查機制」

三、安全組織：CC-23000

編　號	作業項目	作業程序及控制重點	依據資料
CC-23000	安全組織	(一)公司應配置適當人力資源及設備負責資訊安全制度之規劃、監控及執行資訊安全管理作業，所稱配置適當人力資源之規定如下： 1.實收資本額達新臺幣二百億元以上之公司，應設置資訊安全專責單位，該單位應配置專責主管及至少三名專責人員，專門負責資訊安全相關工作或職務，不得兼辦資訊或其他與職務有利益衝突之業務。 2.實收資本額達一百億元以上，未達二百億元者，應配置資訊安全主管及至少三名資訊安全人員，除兼辦資訊職務外，不得兼辦其他與職務有利益衝突之業務；如已設置資訊安全專責單位者，得配置專責主管及二名專責人員，且專門負責資訊安全相關工作或職務，不得兼辦資訊或其他與職務有利益衝突之業務。 3.實收資本額達四十億元以上，未達一百億元者，應配置資訊安全主管及至少二名資訊安全人員，除兼辦資訊職務外，不得兼辦其他與職務有利益衝突之業務。 4.實收資本額未達四十億元者，應配置至少一名資訊安全人員，除兼辦資訊職務外，不得兼辦其他與職務有利益衝突之業務。 5.外國金融機構、證券商及期貨業依期貨商設置標準在國內設立分支機構經營或兼營期貨業務者，將實收資本額改按指撥營運資金計算。 (二)公司應指定副總經理或高層主管人員，綜理資訊安全政策推動及資源調度事務，並得視需要，成立跨部門之「資訊安全推行小組」。公司符合主管機關所訂一定條件者，應指定副總經理以上或職責相當之人兼任資訊安全長辦理上開業務。 (三)公司應視資訊安全管理需要及所屬資安分級，指定專人或專責單位負責規劃與執行資訊安全工作，且資訊安全人員及主管每年應定期參加十五小時以上資訊安全	一、法令規章： (一)證券暨期貨市場各服務事業建立內部控制制度處理準則第 10 條 (二)「建立期貨商資通安全檢查機制」 (三)99.10.22 科技發字第 0990100575 號函 (四)99.11.5 證期(期)字第 0990059872 號函 (五)107.2.2 金管證期字第 1060049369 號函、107.3.1 金管證期字第 1070304404 號函

編　號	作業項目	作業程序及控制重點	依據資料
CC-23000	安全組織	專業課程訓練或職能訓練並通過評量。其他使用資訊系統之從業人員，每年應至少接受三小時以上資訊安全宣導課程。 (四)公司資訊安全人力、能力及經驗，如有不足之處，得委請外界的學者專家或民間專業組織及團體，提供資訊安全顧問諮詢服務。 (五)資訊處理部門負責電腦化作業之規劃、推動及執行，其功能列舉如下： 1.資訊作業規劃。 2.應用系統之引進、分析、設計、程式撰寫、測試、設置、操作訓練、資料轉換、併行作業、執行及維護等事項。 3.主機系統安全管理、機房管理、設備管理、主機操作、批次作業執行、備援操作、應用系統異動管理、使用者管理。 4.設備之購置、測試及驗收。 5.檔案、程式、文件、媒體及報表管理。 6.備援回復計畫、資訊教育訓練等有關之綜合事項。 (六)資訊處理部門與業務單位在組織功能上之權責必須明確劃分。在執行資訊系統相關業務時，應明確劃分業務範圍、責任及權限，實施適切的業務組織分工，以有效發揮相互制衡體制之功能。舉例業務組織之分工如下： 1.程式撰寫： 設計者、程式撰寫者等。 2.資料輸入：開立傳票者、資料整理檢核者、資料登錄者等。 3.資訊系統之操作： 電腦操作員、操作申請人、操作核准人、操作驗證人等。 4.檔案管理：程式檔案管理者、資料檔案管理者等。 (七)資訊處理部門之組織功能應明確訂出。	

編　號	作業項目	作業程序及控制重點	依據資料
CC-23000	安全組織	(八)資訊處理部門內各單位職掌設計，應避免與不同單位權責重疊。 (九)公司應依其所屬資安分級要求資安人員取得並維持相當資通安全專業證照。	

四、資訊資產分類與控制：CC-24000

編　號	作業項目	作業程序及控制重點	依據資料
CC-24000	資訊資產分類與控制	(一)資訊資產應列有清冊，清冊並應加以維護。 (二)應訂有資訊分級並作標示處理之相關規範(適用網際網路下單期貨商)。 (三)資訊資產清冊應指派專人管理，並隨時更新。 (四)資訊分級(例如：區分機密性、敏感性及一般性)之相關規範應配合相關法令規章修訂予以更新。 (五)公司應對自行或委外開發之資訊系統完成資訊系統分級，資訊系統等級應至少區分核心與非核心系統，每年應至少檢視一次資訊系統分級妥適性。 (六)公司應對資訊資產之資料與文件的保存期限進行規範，並於保存期限到期後進行刪除與銷毀。	一、法令規章： (一)證券暨期貨市場各服務事業建立內部控制制度處理準則第 10 條。 (二)「建立期貨商資通安全檢查機制」

五、人員安全：CC-25000

編　號	作業項目	作業程序及控制重點	依據資料
CC-25000	人員安全	(一)員工應依相關法令課予機密維護責任，並應填具保密切結書，以明責任。 (二)員工離職時應取消其識別碼，並收繳其通行證、卡及相關證件。 (三)應定期(每年至少乙次)對全公司員工辦理資訊安全宣導講習(例如：資訊安全政策、資訊安全法令規定、資訊安全作業程序以及如何正確使用資訊科技設施等)，並留存紀錄。 (四)員工應依職務層級進行適當的資訊安全教育訓練，每年並達內部所定之訓練時數。 (五)期貨商應設置電腦稽核人員。(適用網際網路下單期貨商)	一、法令規章： (一)證券暨期貨市場各服務事業建立內部控制制度處理準則第 10 條 (二)「建立期貨商資通安全檢查機制」

六、實體及環境安全：CC-26000

編　號	作業項目	作業程序及控制重點	依據資料
CC-26000	實體及環境安全	(一)電腦機房應設有適當之門禁管制(例如：刷卡)。機房內應有防火設施及緊急照明設備，並應定期檢驗。另應將地震、水災等天然災害因素列入考量。 (二)電腦設備應有獨立之空調系統供其使用，供給空調系統之電力來源應自成一系統。 (三)機房內溫濕度應維持正常。 (四)電腦設備之電源供應系統，應含不斷電設備及發電機。 (五)不斷電系統、發電機等電源供應設備，應定期或不定期測試其堪用性。 (六)電腦系統使用之空調、電源等相關設備，應有適當之備援對策。 (七)機房指派專人管理，其作業項目如下： 1.機房門口應揭示值班操作人員姓名及值班期間。 2.機房應設出入登記簿，記錄除系統管理人員及值班操作人員外之出入狀況。 3.使用機房內機具應經機房值班人員或系統管理人員同意。 4.機房內各項作業情形，應設置工作日誌記錄。 (八)為確保電腦系統正常運作，應委託電腦公司定期做保養、維護工作。 (九)硬體設備發生故障，應即根據維護合約請廠商派員前來維護。 (十)廠商維護人員於維修設備時，應有相關人員會同檢修。 (十一)電腦系統維護工作，應避免停機並干擾使用者，儘可能安排在夜間、假日或無人使用狀態下進行停機作業之處理。 (十二)為確定電腦設備維護內容，應與廠商訂有書面維護契約，完成維護時應留存維護紀錄並由資訊單位派人會同廠商維護人員共同檢查。 (十三)因經營業務需要而為個人資料之蒐集、電腦處理或國際傳遞及利用，應訂定「與軟硬體廠商機密維護及損害賠償等雙方權責劃分」。	一、法令規章： (一)證券暨期貨市場各服務事業建立內部控制制度處理準則第 10 條 (二)「建立期貨商資通安全檢查機制」 (三)98.2.27 台期交字第 09800017290 號函 (四)101.3.6 證期(資)字第 1010008175 號函 (五)99.10.22 科技發字第 0990100575 號函 (六)99.11.5 證期(期)字第 0990059872 號函 (七)88.9.22(88)台財證(七)字第 03574 號函

編　號	作業項目	作業程序及控制重點	依據資料
CC-26000	實體及環境安全	(十四)公司依其業務需要，可租用或委外建置電腦機房，或租用或分租電腦設備及系統，惟公司電腦主機非置於其營業處所者，其提供相關設備與場地之資訊廠商必須事先書面同意期交所必要之檢查，且當有問題發生時，公司必須於知悉或事實發生之日起 5 個營業日內主動以電話及書面通報期交所。公司於向期交所申請將其電腦主機置於營業處所外時，同時提供上開書面同意之證明文件。公司電腦主機置於營業處所外者，仍須依期交所交易資訊使用管理辦法第十九條規定函請期交所同意，及依內部控制制度「電腦作業與資訊提供」之相關作業及委外管理規範辦理。 (十五)應訂定設備報廢作業程序，報廢前應將機密性、敏感性資料及授權軟體予以移除、實施安全性覆寫或實體破壞，應確保報廢之電腦硬碟及儲存媒體儲存之資料不可還原，並留存報廢紀錄，若委託第三者銷毀時，應簽訂保密合約。 (十六)電腦機房硬體設備之運轉情況及故障情況應留存紀錄，並向資訊單位負責人報告。 (十七)各硬體設備故障之原因經分析後，應採取適當之措施，其處理情形亦應列入紀錄。 (十八)應定期審查資訊機房門禁管制權限。	

七、通訊與作業管理：CC-27000

編　號	作業項目	作業程序及控制重點	依據資料
CC-27000 CC-27010	通訊與作業管理 網路安全管理 (適用提供網際網路下單之期貨商，(一)、(二)、(六)項適用全體期貨商)	(一)網路系統安全評估： 1.應定期評估自身網路系統安全(例如：作業系統、網站伺服器、瀏覽器、防火牆及防毒版本等)，並留存相關紀錄。 2.應定期或適時修補網路運作環境及作業系統之安全漏洞(含伺服器、攜帶型、個人端及營業處所內供交易人共用之電腦等)，並留存相關文件。 3.有關電腦網路安全(如資訊安全政策宣導、防範網路駭客入侵事件、電腦防毒等)之事項應隨時對內部公告。 4.各電腦主機、重要軟硬體設備應有專人負責。 5.應定期(至少每半年乙次)辦理資訊系統弱點掃描作業，針對所辨識出之潛在系統弱點，應評估其相關風險或安裝修補程式，並留存紀錄。 6.網路應依用途區分為 DMZ、營運環境、測試環境及其他環境，並有適當區隔機制(如防火牆、虛擬區域網路、實體隔離等)。 7.個人資料及機敏資料應存放於安全的網路區域，不得存放於網際網路等區域。 8.系統應僅開啟必要之服務及程式，未使用之服務功能應關閉。 9.應建立遠端連線管理辦法，對使用外部網路遠端連線至公司內部作業系統維護作業進行控管(如連線 IP 位址、安全網路連線及定期權限審查等)及身分認證，留存相關維護紀錄並由權責主管定期覆核。 10.應防止未經授權設備使用內部網路。 11.應避免使用生命週期終止(End of Service， EOS/End of Life, EOL)之網路設備，並針對 EOS/EOL 之網路設備擬定汰除相關計畫。	一、法令規章： (一)證券暨期貨市場各服務事業建立內部控制制度處理準則第 10 條 (二)「建立期貨商資通安全檢查機制」 (三)證券商、期貨商電子憑證交付作業要點 (四)98.8.13 金管證期字第 0980036706 號函 (五)104.7.20 台期輔字第 10400021740 號函 (六)88.9.22(88)台財證(七)字第 03574 號函 (七)89.6.13(90)台財證(七)第 135895 號函 (八)107.2.2 金管證期

編　號	作業項目	作業程序及控制重點	依據資料
CC-27010	網路安全管理(適用提供網際網路下單之期貨商，(一)、(二)、(六)項適用全體期貨商)	(二)網路設備之安全管理： 1.應建立防火牆。 2.防火牆應有專人管理。 3.防火牆進出紀錄及其備份應至少保存三年。 4.重要網站及伺服器系統應以防火牆與外部網際網路隔離。 5.防火牆系統之設定應經權責主管之核准。 6.公司應每年定期檢視並維護防火牆存取控管設定，每半年檢視 DMZ 區之防火牆規則，並留存相關檢視紀錄。 7.公司交易相關網路直接連線之設備不得使用危害國家資通安全產品。 8.公司建立網路設備規則應以最小授權及正面表列為原則。 9.公司應至少每年檢視一次對外網路設備規則，並留存相關紀錄。 (三)網路傳輸及連線安全管理： 1.網路下單畫面應採加密方式(例如：SSL)處理。 2.公司應每日針對核心系統之帳號登入失敗紀錄、非客戶帳號嘗試登入紀錄等進行監控及分析，發現有帳號登入異常情事(如密碼輸入錯誤達三次、一定時間內大量帳號登入失敗、帳戶申請或更新憑證下載異常)，應即時了解異常原因，並留存相關紀錄。 3.公司提供網路下單服務，應於網路下單登入時採多因子認證方式(例如：固定密碼、圖形鎖、下單憑證、綁定裝置、OTP、生物辨識等機制，以確保為客戶本人登入。	字第 1060049369 號函、107.3.1 金管證期字第 1070304404 號函 (九)109.2.24 台期作字第 10907001030 號函 (十)110 年 1 月 8 日台期輔字第 1100400022 號函

編　號	作業項目	作業程序及控制重點	依據資料
CC-27010	網路安全管理 (適用提供網際網路下單之期貨商，(一)、(二)、(六)項適用全體期貨商)	(四)多因子驗證： 公司使用多因子驗證應具下列三項之任兩項技術： 1.公司所約定之資訊，且無第三人知悉（如固定密碼、圖形鎖或手勢等）。 2.客戶所持有之實體設備（如密碼產生器、密碼卡、晶片卡、電腦、行動裝置、憑證載具等），公司應確認該設備為客戶與公司所約定持有之設備。 3.客戶提供給公司其所擁有之生物特徵（如指紋、臉部、虹膜、聲音、掌紋、靜脈、簽名等），公司應直接或間接驗證該生物特徵。 (五)身分認證與憑證管理： 1.網路下單應訂定憑證交付程序，避免非本人取得憑證並應依下列方式辦理： (1)當面或以電子方式交付憑證下載密碼，並依據該密碼交付憑證，並留存相關紀錄。 (2)客戶申請或更新憑證下載，必須採用多因子(如：下單憑證、綁定裝置、OTP、生物辨識及 SIM 認證等)驗證方式，且與登入帳戶時使用之因子不同，確實辨認客戶身分並留存紀錄。 上述應臨櫃辦理事項，期貨商得接受交易人使用憑證機構憑證實務作業基準所允許之其他方式辦理。 2.網路下單應全面使用認證機制，且公司應按月統計所屬交易人網路下單有效開戶數(指開立網路下單並完成數位憑證下載者)，並與所購置之憑證數量相核對，以檢視數位憑證有無逾期失效或數量不足情形。 3.公司應於伺服器端驗證客戶交易身分及使用者帳號。	

編　號	作業項目	作業程序及控制重點	依據資料
CC-27010	網路安全管理 (適用提供網際網路下單之期貨商，(一)、(二)、(六)項適用全體期貨商)	4.公司對電子交易身分之申請、交付、使用、更新與驗證應訂定相關規範。 (六)電腦病毒及惡意軟體之防範： 1.應安裝防毒軟體，並及時更新程式及病毒碼。 2.應定期對電腦系統及資料儲存媒體進行病毒掃瞄(含電子郵件)。 3.防毒應涵蓋個人端(含攜帶型及營業處所內供交易人共用之電腦等)及網路伺服器端電腦。 4.勿開啟來歷不明之電子郵件，對於電子郵件中帶有執行檔之附件，尤應特別小心開啟。 5.為防範電腦病毒擴散，影響電腦安全，公司應訂定電子郵件使用安全相關規定及建立郵件過濾機制。 6.應建置電腦使用者 IP 配置表，包含控管外來電腦所使用的 IP，以便即時隔離中毒電腦，阻絕繼續擴散。 7.應建立上網管制措施，以避免下載惡意程式。 8.應偵測釣魚網站及惡意網站連結並提醒客戶防範網路釣魚。 9.宜每年定期辦理社交工程演練，並對誤開啟信件或連結之人員進行教育訓練，並留存相關紀錄。 (七)網路系統功能檢查： 1.應定期檢查網路下單系統提供之功能，並留存紀錄。 2.公司應就提供外部連線使用網路系統偵測網頁與程式異動、記錄並通知相關人員處理。	

編　號	作業項目	作業程序及控制重點	依據資料
CC-27010	網路安全管理 (適用提供網際網路下單之期貨商，(一)、(二)、(六)項適用全體期貨商)	(八)公司接受電子交易客戶以電子憑證認證申請補發密碼，應符合期交所 104.7.20 台期輔字第 10400021740 號函規定之「期貨商補發電子交易網站密碼作業規範」： 1.公司受理申請時，應有具體之身分確認措施，經確認申請人身分無誤後，始得將暫時之通行密碼傳送該交易人，該交易人得以該組密碼進入申請補發密碼之網頁申請密碼補發，公司並應就該暫行密碼之登錄有效次數及期限訂定規範。 2.公司線上申辦網頁，應全程使用 SSL 安全機制設計。 3.線上申請密碼補發之電子表單，內容應至少包含身分證字號及出生年月日等內容。 4.申請人應使用有效之 CA 數位憑證，簽署密碼補發之電子表單。 5.公司應確認申請人身分並留存相關紀錄後，始得開啟補發密碼功能。 6.身分確認之錯誤次數達 3 次者，公司應鎖定該下載帳號並中斷連線，非俟交易人臨櫃辦理或經公司確認其身分無誤後，不得解除。 7.以電子郵件方式寄送補發密碼，應比照網路交易認證機制，須透過憑證機構之資料加密等功能，並妥善保存相關傳送及回傳之資訊，以確保密碼傳送之安全性。 (九)公司辦理網際網路等電子式交易型態受託買賣業務，應辦理如下事項： 1.交易主機中應設涵蓋期貨管理法令有關買賣限制或禁止規定之必要檢查點控制項目，並至少包含下列各項： (1)受託買賣期貨交易契約之正確性及其漲跌幅限制之控管。 (2)客戶未沖銷部位及保證金餘額之控管，同一期貨商(含總分公司)同一客戶之未	

編　號	作業項目	作業程序及控制重點	依據資料
CC-27010	網路安全管理 (適用提供網際網路下單之期貨商，(一)、(二)、(六)項適用全體期貨商)	沖銷部位應予歸戶計算。 (3)特殊身分客戶交易限制之控管，如華僑、外國人、期貨商內部人員等。 (4)交易帳戶有效性之控管，如開戶手續未完備、違約及註銷帳戶之禁止買賣。 (5)買賣委託紀錄應行記載事項之控管，如經辦人員、部門主管之簽章，委託紀錄應含委託人帳號及戶名、委託方式、委託日期、時間及委託有效期限、期貨交易所名稱、期貨交易之種類、數量及交割月份、市價委託、限價委託、一定範圍市價委託或其他下單方式、業務員姓名或代碼等；委託人以電話語音委託者，期貨商應配合電信機構開放顯示發話端號碼之功能，記錄委託人之來電號碼，惟列印委託紀錄時得免列印。 2.與交易有關業務憑證(包括書面文件或電腦紀錄)之保存年限應依臺灣期貨交易所訂定之「期貨商、結算會員帳表憑證保存年限表」規定辦理。 3.對客戶經由網際網路等電子式交易型態所為之交易委託及查詢，其電腦稽核紀錄應至少保留五年。但買賣委託有爭議者，應保留至爭議消除為止。 4.公司轉接傳輸即時資訊應依期交所「交易資訊使用管理辦法」、「交易資訊使用費收費標準」、及 109.2.24 台期作字第 10907001030 號函規定辦理，經期交所同意得將即時資訊轉接傳輸予其開戶之交易人作為非揭示使用，並應與接收資訊之交易人約定應遵守「交易資訊使用管理辦法」中，有關資訊用戶使用交易資訊之相關規定，且應於每月 10 日前至期交所媒體申報系統申報非揭示使用資訊用戶資料。 (十)網路攻擊防護機制導入及安全性檢測：	

編　號	作業項目	作業程序及控制重點	依據資料
CC-27010	網路安全管理(適用提供網際網路下單之期貨商，(一)、(二)、(六)項適用全體期貨商)	1.公司應依其所屬資安分級定期對提供網際網路服務之核心系統辦理滲透測試，並依測試結果進行改善。 2.公司應依其所屬資安分級定期辦理資通安全健診（應含網路架構檢視、網路惡意活動檢視、使用者端電腦惡意活動檢視、伺服器主機惡意活動檢視、目錄伺服器設定及防火牆連線設定檢視）。 3. 公司應依其所屬資安分級建立資通安全威脅偵測管理機制（應含括事件收集、異常分析、偵測攻擊並判斷攻擊行為） 4.公司應依其所屬資安分級建立入侵偵測及防禦機制。 5.公司應依其所屬資安分級設置應用程式防火牆。 6.公司應依其所屬資安分級辦理進階持續性威脅攻擊防禦措施。 7.核心系統身分驗證機制應防範自動化程式之登入或密碼更換嘗試，非核心系統宜防範自動化程式之登入或密碼更換嘗試。 (十一)網際網路下單服務品質相關標準： 公司提供網際網路下單業務時，兼顧客戶服務品質，應訂定網際網路下單服務品質相關標準，並應包含下列重點： 1.交易之安全性：包括建立相關資訊安全機制，並擬定緊急應變計畫及備援措施。 2.交易之穩定及系統可用性：為維持網路交易之順暢與便捷，應定期評估系統可用性並留存紀錄，就網路下單客戶數、交易流量及預期將來交易量，現有設備是否足以負載、是否需擴充相關軟硬體設備，以避免發生網路塞單、委託成交速度遲緩甚或當機之風險。	

編　號	作業項目	作業程序及控制重點	依據資料
CC-27010	網路安全管理 (適用提供網際網路下單之期貨商，(一)、(二)、(六)項適用全體期貨商)	(十二)帳號登入或異常態樣通知： 公司對於客戶帳號登入時宜進行通知，如有符合以下異常態樣應即通知客戶，並留存紀錄，避免非客戶本人登入情事： 1.密碼輸入錯誤或帳戶被鎖定。 2.申請或更新憑證。 3.變更基本資料。 4.異常來源或行為嘗試登入等。 5.密碼申請異動或補發時。 (十三)異常 IP 登入之監控與預警： 公司對異常及不明來源 IP 連線進行監控分析及留存紀錄，如有發現下列情形，應設有警示機制，並定期檢視以確認機制有效運作： 1.同一來源 IP 登入不同帳號達一定次數以上。 2.同一帳號在一定時間內由不同國家登入。 3.發現異常來源（如金融資安資訊分享與分析中心 F-ISAC 公布之黑名單或國外 IP)嘗試登入。	

編　號	作業項目	作業程序及控制重點	依據資料
CC-27020	電腦系統及作業安全管理	(一)電腦設備之管理： 1.指派專人依據下列資料擬訂採購規格： (1)資訊作業發展計畫。 (2)環境評估報告。 (3)系統設置計畫。 (4)備援及回復計畫。 (5)臨時性需求。 2.依相關採購法規辦理採購、安裝、測試及驗收等作業。 3.驗收後之設備列入不動產及設備管理。 4.應設置系統管理人員。 5.為確定電腦設備維護內容，應與廠商訂有書面維護契約，完成維護時應留存維護紀錄並由資訊單位派人會同廠商維護人員共同檢查。 (二)電腦作業系統環境設定及使用權限設定： 1.主機系統設定項目： (1)系統內定值設定。 (2)終端機及終端印表機之組態設定。 (3)通訊組態設定。 (4)系統各項作業之環境設定。 (5)各項標的之權限設定。 2.電腦主機系統配合業務種類、作業性質及程式和檔案的使用，作以下之安全設	一、法令規章： (一)證券暨期貨市場各服務事業建立內部控制制度處理準則第 10 條 (二)「建立期貨商資通安全檢查機制」 (三)99.10.22 科技發字第 0990100575 號函 (四)99.11.5 證期(期)字第 0990059872 號函 (五)107.2.2 金管證期字第 1060049369 號函、107.3.1 金管證期字第 1070304404 號函

編　號	作業項目	作業程序及控制重點	依據資料
CC-27020	電腦系統及作業安全管理	計： (1)建立使用者名稱(USERCODE)：按業務種類及作業性質建立不同之使用者名稱分別供各作業系統使用，確保檔案之完整及安全。 (2)使用者密碼(PASSWORD)：按作業系統訂定使用者密碼，以管制不同程式或不同使用者，僅可更新或查詢指定檔案，確保檔案的機密性。 (3)使用者權利(ACCESSCODE)：按使用人員或同一作業系統劃分不同ACCESSCODE，以管制某一作業程式可使用之檔案。 (4)使用者權利密碼(ACCESS PASSWORD):針對某一檔案只允許某些程式可使用，除了訂定 ACCESSCODE 外，另訂 ACCESS PASSWORD 以保護檔案不被無關人員使用。 3.設定作業需求之提出需經系統管理人員簽註意見後陳請有關主管核示。 4.上述之設定工作由系統管理人依據書面核定資料執行，作業完成後之結果通知申請人並存查。 5.電腦作業系統環境設定及使用權限設定應經有關主管核示，並由系統管理人員執行。 6.電腦系統檔案異動前後皆應有完善之備份處理措施。 7.應建立系統最高權限帳號管理辦法(含作業系統及應用系統)，如需使用最高權限帳號時須取得權責主管同意，並留存相關紀錄。 8.應建立並落實個人電腦、伺服器及網路通訊設備之安全性組態基準(如密碼長度、更新期限等)。	

編　號	作業項目	作業程序及控制重點	依據資料
CC-27020	電腦系統及作業安全管理	9.透過網際網路使用帳號登入系統時，應採用多因子認證機制。 10.資通系統內部時鐘應定期與基準時間源進行同步。 11.公司應依其所屬資安分級對核心系統重要組態設定檔案及其他具保護需求之資訊進行加密或以其他適當方式儲存。 12.公司應依其所屬資安分級訂定對核心系統之閒置時間或可使用期限與核心系統之使用情況及條件(如：帳號類型與功能限制、操作時段限制、來源位址限制、連線數量及可存取資源等)。 (三)電腦媒體之安全管理： 1.由主機操作人員依據作業申請單及經核定之備援回復計畫執行儲存媒體備援工作。 2.備份後之儲存媒體應指派專人管理。 3.備份後之儲存媒體應存放在不同地點。 4.備份後之儲存媒體應定期抽測試讀。 5.存放備份資料之儲存媒體，應於其標籤上註明存放資料之名稱及保存期限。 6.應建立機密性及敏感性資料媒體之相關處理程序，防止資料洩露或不當使用。 7.重要軟體及其文件、清冊應抄錄備份存於另一安全處所。 8.重要之備份檔案及軟體若儲存於與電腦中心同一建築物內，應鎖存於防火之房間或防火且防震之防火櫃中。 9.應建立回存測試機制，以驗證備份之完整性及儲存環境的適當性。 10.公司應依據系統特性與資料復原點目標（RPO），考量備份頻率、儲存媒體類型	

編　號	作業項目	作業程序及控制重點	依據資料
CC-27020	電腦系統及作業安全管理	（光碟、外接硬碟、磁帶）、資料類型（虛擬機映像檔、系統源碼、資料庫與組態設定檔等）、備份類型（完整備份、增量備份與差異備份）、備份方式（網路同步寫入、網路非同步寫入與離線備份）等，制定適當之資料備份機制，如採離線備份應依備份類型建立適當的備份基準(baseline)，以確保資料可正確回存。 11.公司制定資料備份機制時，宜考量「3-2-1 備份原則」，至少製作三份備份；將備份分別存放在兩套獨立不同儲存設備；至少一份放在異地保存。 (四)電腦操作管理： 1.電腦操作過程中所需之各項定期及不定期作業由應用系統維護人員提出作業申請單。 2.作業申請單經有關主管核示後由操作人員執行。 3.操作人員執行之各項操作程序應有完整之操作手冊，以提供操作人員按指示執行。 4.操作人員執行之每項步驟，應在操作程序紀錄表上詳實記錄，並每天呈主管核驗。 5.操作人員所有輸入，電腦系統應留下紀錄並由主管核驗。 6.操作人員應留意系統主控台訊息，如有異常應緊急通知相關人員，並將異常訊息記錄於操作日誌。 7.操作人員如遇到硬體故障時，應立即連繫電腦硬體工程人員，並將處理時間記錄於操作日誌。 8.為正確且安全運轉資訊系統，應訂定日常各種作業處理程序手冊。	

編　號	作業項目	作業程序及控制重點	依據資料
CC-27020	電腦系統及作業安全管理	9.操作人員應確實依規定操作程序執行。 10.操作日誌應詳實記載並逐日經主管核驗，操作人員不可與主管為同一人。 11.系統主控台所留存之紀錄，應經專人檢查訊息內容且定期送主管核驗。 12.操作疏失應檢討改進。 (五)公司(期貨經紀商)應配備經營業務所需、且有適足容量之電腦系統。 (六)公司(期貨經紀商)之電腦系統應訂定定期(每年至少一次)由內部或委託外部專業機構評估電腦系統容量及安全措施之機制與程序，定期對系統容量進行壓力測試，並留存紀錄。	

八、存取控制：CC-28000

編　號	作業項目	作業程序及控制重點	依據資料
CC-28000	存取控制	(一)公司應訂定資訊系統存取控制相關規定，並以書面、電子或其他方式告知員工遵守。 (二)權限管理：(電腦系統管理－系統使用者管理) 1.申請使用系統資源之人員以書面提出申請： (1)申請內容應註明使用目的及權限。 (2)使用人為應用系統使用者則需經應用系統負責人簽註意見。 (3)每一使用者限用唯一代碼。 2.申請內容應經使用單位主管及資訊單位主管核可後辦理。 3.本項結果由系統管理人員依核定結果執行。 4.使用者因業務需要或職務變動等因素而需增加、刪除或變更使用權限時亦應提出更動需求。 5.查核委外人員所使用之電腦紀錄，確認未授予委外人員過高之電腦通行使用權利或不當使用權，且於委外期間結束後，立即收回該項權利，以免被盜用、竄改資料。 6.對於進駐於公司內之委外作業人員應納入公司安全管理，如欲使用內部網路資源時，應有安全管制措施(如透過轉接方式或另建網路者，宜與內部網路作實體隔離)。 7.應定期(至少每半年一次)審查資通系統帳號及權限之適切性，並視審查結果停用資通系統閒置帳號。(客戶帳號除外)。 8.對於程式的存取使用，應有詳細的書面管制說明。	一、法令規章： (一)證券暨期貨市場各服務事業建立內部控制制度處理準則第 10 條 (二)「建立期貨商資通安全檢查機制」 (三)個人資料保護法 (四)公開發行公司網路申報公開資訊應注意事項 (五)99.10.22 科技發字第 0990100575 號函 (六)99.11.5 證期(期)字第 0990059872 號函 (七)107.2.2 金管證期字第 1060049369 號函、107.3.1 金管證期字第 1070304404 號函 (八)110 年 1 月 8 日台

編　號	作業項目	作業程序及控制重點	依據資料
CC-28000	存取控制	9.人員異動時應及時更新其使用權限。 10.對於程式及檔案之存取使用，應按權限區分。 11.公司應建立資通系統帳號管理機制，包含帳號之申請、建立、修改、啟用、停用及刪除之程序。 12.資通系統帳號應定義人員角色及責任，授權應採最小權限原則，僅允許使用者(或代表使用者行為之程序)依公司部門權責及業務功能，完成作業所需之授權存取。 (三)公司密碼管理： 1. 使用者申請使用代碼時應於接到使用許可後立即更新密碼。 2.初始密碼應隨機產生，並與使用者或客戶身分無關。 3.密碼輸入錯誤次數達五次者，應予中斷連線及鎖定該帳號至少十五分鐘不允許該帳號繼續嘗試登入，並留存紀錄。公司於接獲客戶聯繫申請解除鎖定時，應確實辨認身分（如聯繫客服驗證基本資料、OTP、臨櫃辦理等方式），並留存相關紀錄後，始得辦理之。 4.對因忘記密碼而無法登入系統之使用者或客戶申請核發原密碼時，應採取嚴格確認其身分及核發程序後（如聯繫客服驗證基本資料、OTP、臨櫃辦理等方式），方可開放其使用系統。 5.除語音按鍵下單外，公司應使用優質密碼設定（長度超過六個字元（含）以上，且具有文數字或符號）並進行管控，及加強宣導客戶定期更新密碼以不超過三個月為宜，如客戶密碼超過一年未變更或變更密碼與前一代相同，公司應做妥	期　輔　字　第 1100400022 號函

編　號	作業項目	作業程序及控制重點	依據資料
CC-28000	存取控制	善處理。除客戶外，公司其他使用者之密碼應至少每三個月變更一次。 6.檢查公司現有之網站、伺服器、網路芳鄰、路由器、交換器、作業系統及資料庫等軟硬體設備應設定使用密碼，且避免使用預設(如 administrator、root、sa)或簡易(如 1234)之帳號密碼及未設管理者存取權限。 7.網路下單應訂定密碼交付程序，避免非本人取得密碼。 8.為防止密碼洩漏，應採取不顯示、不印錄等措施。 9.使用者第一次使用系統時，應更新初始密碼後方可繼續作業。 10.密碼應使用公開安全且未遭破解之演算法(例如：雜湊演算法等不可逆運算式)產生亂碼並加密儲存。 (四)電腦稽核紀錄管理： 1.對重要系統(如主機連線系統、網路下單系統等)之稽核日誌紀錄內容應包括使用者識別碼、登入登出之日期時間、電腦的識別資料或其網址及事件描述等事項。 2.對上開重要系統之電腦稽核紀錄，應有專人定期檢視。 3.相關留存紀錄應確保數位證據之收集、保護與適當管理程序，至少留存三年。 4.核心系統電腦稽核紀錄(日誌)應建立監控機制，處理失效時，應採取適當之行動。 (五)資料輸入管理：(電腦作業管理－資料輸入管理) 1.上線應用系統之資料輸入與修改，由業務單位人員依提供之資料進行作業。其執行人員之姓名、職稱應有詳細紀錄，並由專人管理。 2.輸入或修改重要性、安全性或特殊資料，應由權責主管人員核可後始得執行，使用電子憑證IC卡或其他類型憑證晶片卡或其他憑證載具等代表公司簽署之作業	

編　號	作業項目	作業程序及控制重點	依據資料
CC-28000	存取控制	(例如：「期貨商申報單一窗口」、「公文電子交換系統」等)，該等憑證載具應由專人負責保管並設簿登記，且應訂定相關帳號、密碼保管及使用程序，並據以執行。 3.所輸入或修改之資料應留存紀錄，並核對資料之正確性；其使用前揭代表公司憑證載具簽署之作業系統端(server 端)若屬期貨商應用系統者(例如：「電子對帳單系統」)，應留存電腦稽核紀錄(log)，其保存年限比照各作業資料應保存年限。 4.對重要及機密性檔案，應使用密碼或存取控制軟體限制其使用或設定等級，按等級使用。 5.對隱密性高之重要資料(例如密碼檔)應以亂碼後之資料形式存放。 6.保有個人資料檔案者，應指定專人辦理安全維護事項。 7.公司如屬公開發行公司者，應於內部控制制度納入「公開發行公司網路申報公開資訊應注意事項」，並據以辦理相關申報事宜。 8.公司應依「個人資料保護法」妥善處理公司保有之個人資料，並定期或不定期稽核依「個人資料保護法」定義之個人資料管理情形。 9.前揭個人資料檔案之資料，其更新、更正或註銷均應報經核准，並將更新、更正、註銷內容、作業人員及時間詳實記錄。 10.對重要及機密性檔案其存取使用應依規定之作業程序辦理。 11.應依「個人資料保護法」，妥善處理客戶及公司內部人個人資料。 12.應留存個人資料使用稽核軌跡（如登入帳號、系統功能、時間、系統名稱、查詢指令或結果）或辨識機制，以利個人資料外洩時得以追蹤個人資料使用狀況。	

編　號	作業項目	作業程序及控制重點	依據資料
CC-28000	存取控制	(六)資料輸出管理：(電腦作業管理－資料輸出管理) 1. 報表之列印應由經授權之人員按時執行產出，產生之報表分送各使用單位。 2.輸出資料使用後若無保存需要，應經適當銷毀處理。 3.輸出資料若以磁性媒體保存，應定期檢查以確定必要時能以報表方式印出。 4.機密性、敏感性之報表列印或瀏覽應有適當之管制程序。 5.交易人於公司網站查詢個人資料應具有加密傳輸機制(例如：SSL)，以確保交易人於網站查詢資料之保密性。	

九、系統開發及維護：CC-29000

編　號	作業項目	作業程序及控制重點	依據資料
CC-29000	系統開發及維護	公司經營之業務項目(如經紀、自營)，其系統開發維護相關事宜，均需依據本作業項目之規範內容辦理。 (一)系統分析： 1.依資訊作業發展計畫，確定欲開發系統之預定作業方式、作業項目、作業內容及作業時程。 2.依規定呈權責主管核示，以確定作業方式係採用委託開發、直接引用現成系統或自行開發。 3.作業方式如採委託開發則依採購程序辦理委託開發，作業方式如採直接引用現成系統則依程序向被引進系統之著作權所有人引進應用系統。 4.與業務單位共同研討、評估業務需求，確定電腦化後之作業方式並完成需求分析報告。 5.評估系統引進、開發、維護等過程中所需之各項軟硬體資源後，提出環境評估報告。 6.將需求分析及環境評估等報告依規定呈有關主管核示後確認作業方式。 7.應用系統在規劃分析時應將資訊安全需求納入分析及規格。 8.已認可之系統開發計畫應包含下列項目： (1)計劃之目的及範圍皆有周詳之定義。 (2)針對各種可行方案合理估計成本效益並作比較分析。 (3)依系統開發階段訂定合理的進度表。 9.系統分析報告應包含下列項目：	一、法令規章： (一)證券暨期貨市場各服務事業建立內部控制制度處理準則第 10 條 (二)「建立期貨商資通安全檢查機制」 (三)95.3.27 台期資字第 09500026000 號函 (四)99.6.28 金管證期字第 0990029082 號函 (五)99.10.22 科技發字第 0990100575 號函 (六)99.11.5 證期(期)字第 0990059872 號函 (七)105.7.15 台期輔字第 10504005170 號函

編　號	作業項目	作業程序及控制重點	依據資料
CC-29000	系統開發及維護	(1)現行系統之問題點及其改善方式。 (2)新系統之成本效益比較分析。 (3)新系統之輸入、輸出及內部流程之明確列出。 (二)環境評估報告： 1.環境評估報告應依規定製作並於系統分析完成後提出。 2.環境評估報告內容至少包含下列項目： (1)所開發系統或被引進系統之簡介。 (2)所開發系統或被引進系統之作業所需軟、硬體環境。 (三)系統引進： 1.依系統分析後之決定按規定程序引進有合法版權之套裝軟體。 2.如應用系統委託專業機構辦理者，應注意下列重點： (1)委外作業應簽訂契約，委外作業契約內容應包含資訊安全協定、對委外廠商資安稽核權與要求受託機構應遵守期貨管理法令、個人資料保護法、消費者保護法及其他法令之規定等條款。前開資安稽核權包含同意期貨主管機關、期交所及期貨商進行實地查核，並依指示於期限內提供書面資料及說明。 (2)委外作業之開發、設計、程式撰寫、測試、驗收等各階段依合約規定程序進行，並備妥各階段之相關文件。 (3)資訊軟、硬體設備及作業管理有委外管理情形者，應於委外契約(至少應含委外管理範圍、委外管理期間、委外管理費用、委外管理責任、智慧財產權協議、保密義務、查核條款等)中明確訂定雙方電腦資訊作業管理之安全性規範、業務(含內部稽核)之責任區分及雙方之資訊人員管理規範，以達成明確區分期	

編　號	作業項目	作業程序及控制重點	依據資料
CC-29000	系統開發及維護	貨商與接受委外管理公司權責之目的。 (4)資訊軟、硬體設備及作業管理有委外管理情形者，內部稽核人員仍應依內部控制制度之電腦作業與資訊提供循環所規定之週期，確實執行相關稽核作業。 (5)公司應用系統若有複委託之情形，亦應遵循上述規範。 (四)委外廠商管理： 1.公司與委外資訊服務供應商提供服務應訂定合約，合約所含內容應包含以下內容：合約期限、服務範圍、服務交付日期、服務水準要求、服務變更規範、服務驗收之標準、資通安全事件通報及應變處理作業程序、對資訊服務供應商之稽核權條款、合約轉讓或同意分包之規範、保密義務條款、罰則與損害賠償條款、爭議處理程序、違約處理條款、合約終止規範、合約終止後之處理、保固、權利及責任。 2.公司應評估資訊服務供應商之集中度，包括評估資訊服務供應商作業能力，採取適當風險管控措施，確保作業委外處理之品質，並注意作業委託資訊服務供應商之適度分散以控管作業風險。 3.資訊服務供應商應提供安全性檢測證明 (如行動應用程式資安檢測、源碼檢測、弱點掃描等)，並應確保交付之系統或程式無惡意程式及後門程式，其放置於網際網路之程式應通過程式碼掃描或黑箱測試。 4.公司應訂定相關規範管控，與資訊服務供應商資訊委外關係於終止、解除或結束後之相關作業。 5.委外資訊服務供應商應揭露第三方程式元件之來源與授權證明。	

編　號	作業項目	作業程序及控制重點	依據資料
CC-29000	系統開發及維護	6.公司應管控資訊服務供應商存取權限，對於電腦通行使用權利進行適當控管。 7.公司應對資訊服務供應商服務內容變更進行風險評估。 8.公司對於委外資訊服務供應商於委外關係所涉及公司資訊資產，應於委外關係終止、解除或結束時完整歸還、確保銷毀或轉交予其他資訊服務供應商，並要求資訊服務供應商持續遵守保密承諾。 9.委外資訊服務供應商如自行發現程式漏洞、版本老舊，或於使用相同服務之其他期貨商應用系統發生故障或異常時，應儘速瞭解原因，並主動轉知及提供因應措施。 10.委外資訊系統之服務規格書應包括硬體規格、軟體版本、作業環境變動、作業系統底層架構及系統程式相容性等，並包含維持委外廠商服務水準之要求與橫向溝通機制。 (五)系統設計： 1.資料庫設計。資料庫設計之欄位應滿足業務需求，且應預留擴充彈性。 2.系統流程設計。系統作業流程設計應考慮錯誤處理程序。 3.系統輸入設計。輸入資料應作檢查，以確認其正確性。 4.系統輸出設計。 5.處理設計。 6.控制設計。處理過程之控制設計應適切。 7.與有關單位充分研討上述系統規格並修訂。 8.系統規格依規定呈相關權責主管核定後確認。	

編　號	作業項目	作業程序及控制重點	依據資料
CC-29000	系統開發及維護	9.訂定程式設計工作方法。 10.對於交易時間、地點、作業人員及作業內容等事項應記錄足夠供查詢之資訊。 (六)程式撰寫及單元測試： 1.邏輯設計。 2.依規定編定程式代號。 3.依規定撰寫程式說明。 4.依規定語言及方式撰寫程式。 5.程式編譯、測試及修改。 (七)系統測試： 1.訂定測試計畫，其內容至少包含下列項目： (1)測試目的。 (2)測試完成標準。 (3)測試方法。 (4)測試記錄格式。 2.依測試計畫請應用系統使用單位共同測試，且應完整記錄所有測試經過及結果。 3.修改測試過程中之錯誤，並將所有設計上相關之改變配合修訂更新。 4.製作測試報告其內容至少需包含下列項目： (1)測試目的。 (2)測試方法。 (3)測試記錄。	

編　號	作業項目	作業程序及控制重點	依據資料
CC-29000	系統開發及維護	(4)測試結果總評及建議。 5.依系統特性，除整合測試外，視需要增加極端、破壞、壓力等測試，並經權責主管核定後執行，以強化系統之穩定性。 6.程式測試應經由不同人員再行驗證。公司應確實督導所屬人員不得利用客戶帳戶進行期貨交易系統測試。 (八)系統設置計畫： 1.應用系統上線前系統負責人需訂定應用系統設置計畫，其內容含下列項目： (1)應用系統概述。 (2)容量規劃。 (3)程式及檔案之設定權限。 (4)使用者及使用權限與使用環境之設定。 2.應用系統設置計畫由操作管理人員依據核定之文件執行之。 3.系統設置計畫之訂定與執行應確實依作業程序辦理。 (九)應用系統操作訓練： 1.訂定應用系統操作手冊分送使用單位。 2.訓練使用單位人員使用新系統。 (十)資料轉換： 1.訂定資料轉換計畫，其內容至少包含下列項目： (1)轉換時機及負責轉換人員。 (2)轉換方式。	

編　號	作業項目	作業程序及控制重點	依據資料
CC-29000	系統開發及維護	2.資料轉換計畫應呈相關權責主管核定後執行之。 3.進行資料轉換作業前應保留備份資料。 4.比較資料轉換前後新舊系統之執行結果並適時修正錯誤。 5.轉換後併行作業。 6.轉換應挑選恰當之時機。 7.事先考慮新舊系統間無法轉換時資料應如何處理。 (十一)併行測試： 1.於資料轉換作業完成後進行。 2.正式作業資料應同時確實輸入新舊系統。 3.比較新舊系統輸出結果，如有錯誤應即時修正。 4.併行測試正常經相關權責主管核准後正式上線。 (十二)文件整理： 1.新開發之應用系統正式實施前應備妥下列各項說明文件： (1)系統概述。 (2)系統流程圖。 (3)系統代碼表。 (4)系統功能表。 (5)程式規格書。 (6)操作手冊。 2.系統有關之文件應設專人負責保管。	

編　號	作業項目	作業程序及控制重點	依據資料
CC-29000	系統開發及維護	3.系統說明文件應齊全且限於相關業務人員借閱。 4.應用系統維護完成後，應於限期內完成相關文件及手冊之維護。 5.各項文件與手冊應經適當維護與控制。 6.整理後之文件應與系統保持一致。 (十三)系統維護： 1.應用系統之維護應指派專人負責。 2.應用系統之程式、作業方式或其他內容需更動時由提出需求人員填具書面申請資料，交應用系統維護人員表示意見。 3.呈相關權責主管核定後由應用系統維護人員負責辦理。 4.需求經修改測試正常後，依上線應用系統異動管理程序修訂上線應用系統之內容。 5.系統修訂後應將所有設計上相關之改變及時配合修訂，屬於文件修訂部分送文件管理人員配合更新。 6.期貨、選擇權新商品上線前或配合交易系統、結算系統相關作業變更時，應配合進行必要之全市場測試。 7.有關期貨交易前、後台系統功能之開發應符合以下各項要求： (1)業務單位提出需求時應就系統新增、修改之目的、受影響相關作業及應遵循之法規等事項，詳予以載明並依核決權限簽核。 (2)功能開放完成後、換版上線前應會同開發廠商進行需求及功能檢核及測試，並將檢核結果依程序完成簽核。	

編　號	作業項目	作業程序及控制重點	依據資料
CC-29000	系統開發及維護	(3)稽核單位應就上開程序進行稽核及出具報告。 (4)應依前開程序之結果出具聲明書。 8.網路下單交易軟體相關系統進行開發與維護時，應於程式上線前與期交所連線進行功能測試並留存相關紀錄。 9.應制訂程序，定期檢視重要系統資源之使用率及系統容量，適時進行必要之擴充，增加系統之穩定性。 10.已完成之程式因故需維護時，應依據經過正式核准之程序辦理。 (十四)應用系統異動管理： 1.應用系統開發前應由應用系統負責人以書面通知系統管理人員所需之軟硬體資源及使用權限。 2.應用系統上線前系統負責人需訂定應用系統設置計畫，內容含下列項目： (1)應用系統目的。 (2)容量規劃及測試。 (3)程式及檔案之設定權限。 (4)使用者及使用權限與使用環境之設定。 3.應用系統設置計畫由系統管理人員依據核定後文件執行之。 4.為便於管理及安全因素的考慮，在一個系統內，應將「原始程式」「目的程式」及「使用者資料」分別以獨立的「資料館」存放，並將登錄之程式或資料名稱呈核列管。 5.上線系統之執行程序或資料等之新增、修改、刪除等處理除經由正式程式為之	

編　號	作業項目	作業程序及控制重點	依據資料
CC-29000	系統開發及維護	外，只能由系統負責人依核定後結果執行之。 6.上線系統變更時其設計上相關之改變應及時配合更新。 7.正式作業與測試作業之程式、資料、工作控制指令等檔案應分開存放。 8.程式經修改其相關文件應及時更新。 9.應用程式文件應與異動程式相符，正式作業環境之程式應與所異動程式時間相符。 (十五)程式原始碼安全規範（適用網際網路下單期貨商）： 1.程式應避免含有惡意程式等資訊安全漏洞。 2.程式應使用適當且有效之完整性驗證機制，以確保其完整性。 3.程式於引用之函式庫有更新時，應備妥對應之更新版本。 4.程式應針對使用者輸入之字串，進行安全檢查並提供相關注入攻擊防護機制。 5.委外開發之行動應用程式如涉及機敏性資料傳送（如：客戶帳號密碼或交易資料等）應自行或委外檢視驗證傳遞對象是否適當並留存相關紀錄。 6.公司應依上開安全事項檢驗程式原始碼並符合安全事項之要求；無法取得程式原始碼時，應要求程式提供者符合上開前五項安全事項。 (十六)行動應用程式安全管理（適用網際網路下單期貨商）： 1.行動應用程式發布： (1)行動應用程式應於可信任來源之行動應用程式商店或網站發布，且應於發布時說明欲存取之敏感性資料、行動裝置資源及宣告之權限用途。 (2)應於公司網站上提供行動應用程式之名稱、版本與下載位置。	

編　號	作業項目	作業程序及控制重點	依據資料
CC-29000	系統開發及維護	(3)應建立偽冒行動應用程式偵測機制，以維護客戶權益。 (4)應於發布前檢視應用程式所需權限應與提供服務相當，首次發布或權限變動應經資安單位或人員、法遵單位同意，並留有紀錄，以利綜合評估是否符合個人資料保護法之告知義務」。 2.敏感性資料保護： (1)行動應用程式傳送及儲存敏感性資料時應透過有效憑證、雜湊（Hash）或加密等機制以確保資料傳送及儲存安全，並於使用時應進行適當去識別化，相關存取日誌應予以保護以防止未經授權存取。 (2)啟動行動應用程式時，如偵測行動裝置疑似遭破解（如 root、jailbreak、USB debugging 等），應提示使用者注意風險。 3.行動應用程式檢測： (1)涉及交易人使用之行動應用程式於初次上架前及每年應委由經財團法人全國認證基金會(TAF)認證合格之第三方檢測實驗室進行並完成通過資安檢測，檢測範圍以目的事業主管機關委託執行單位「行動應用資安聯盟」公布之行動應用程式基本資安檢測基準項目進行檢測。如通過實驗室檢測後一年內有更新上架之需要，應於每次上架前就重大更新項目進行委外或自行檢測；所謂重大更新項目為與「下單交易」、「帳務查詢」、「身分辨識」及「客戶權益有重大相關項目」有關之功能異動。檢測範圍以 OWASP MOBILE TOP 10 之標準為依據，並留存相關檢測紀錄。 (2) 期貨商對第三方檢測實驗室所提交之檢測報告，應依中華民國期貨業商業同	

編　號	作業項目	作業程序及控制重點	依據資料
CC-29000	系統開發及維護	業公會「新興科技資訊安全自律規範」附錄-檢測實驗室 APP 檢測報告自我檢核表參考範例所列檢測項目建立覆核機制，以確保檢測項目及內容一致，並留存覆核紀錄。 (十七)核心系統應針對風險評估使用者頁面僅顯示簡短錯誤訊息及代碼，不包含詳細之錯誤訊息。 (十八)提供網際網路下單服務之核心系統上架前及系統更新時應執行「源碼掃描」安全檢測。 (十九)與資訊公司異業合作平台，不得提供或介接未經金融監督管理委員會許可之證券期貨業者所提供之證券期貨業務（如證券期貨業務有關之開戶及下單功能）。	

十、營運持續管理：CC-30000

編　號	作業項目	作業程序及控制重點	依據資料
CC-30000	營運持續管理	(一)研擬備援及回復計畫，其內容至少包含下列項目之說明： 1. 資料庫、檔案及程式之備援回復。 2.電腦作業系統備援及回復。 3.電腦設備備援及設備故障回復。 4.通訊設備及線路之備援及回復。 5.電力系統備援及回復。 (二)與業務單位人員研討於重大異常狀況發生時，根據下列時間點，考慮當時系統發生的作業需求型態、影響的業務層面及相關人員應採的應變措施，訂定人工配合之備援計畫，以及需包含電腦系統等故障復原標準作業程序，並落實執行且留存紀錄。 1.開盤前機器無法啟動。 2.盤中交易期間機器停頓。 3.收盤後資料未核對完成前系統發生異常情形。 4.所有交割或清算之作業未完成時系統發生異常。 5.每日日結作業時系統發生異常。 (三)核定之備援及回復計畫由下列人員執行： 1.非人工備援作業由資訊單位人員為之。 2.人工備援作業由使用該應用系統之業務單位人員為之。 (四)重大異常狀況發生時，資訊單位人員應立即檢視電腦系統無法正常運作原因，判定災害等級，影響業務範圍，估計回覆作業時間，衡量當時作業狀況，通知相關人員根據備援及回復計畫所應採取之配合措施。	一、法令規章： (一)證券暨期貨市場各服務事業建立內部控制制度處理準則第 10 條。 (二)「建立期貨商資通安全檢查機制」 (三)100.6.14 台期交字第 10000021010 號函 (四)105.11.23 台期交字第 10500035050 號函 (五)105.12.22 台期交字第 10502018770 號函 (六)107.2.2 金管證期字第 1060049369 號函、107.3.1 金管證期字第 1070304404 號函 (七)100 年 08 月 11 日台期交字第

編　號	作業項目	作業程序及控制重點	依據資料
CC-30000	營運持續管理	(五)不管是電腦系統或是電力、空調、消防系統發生異常，事後相關人員應確實檢討原因，並謀求改進與對應預防措施。 (六)所訂定之重大異常狀況系統復原計劃應定期模擬演練，以使相關人員熟悉重大異常狀況發生時，系統之應變措施及復原程序。 (七)故障復原程序(例如：電腦設備、通訊設備、電力系統、資料庫、電腦作業系統等備援及回復計畫)應明確訂定，並製成文件。 (八)故障復原程序應週期性測試，測試後應召開檢討會議，針對測試缺失謀求改進，並留存紀錄。 (九)公司(期貨經紀商)之交易主機應有備援措施，並依所屬資安分級建置異地備援機房。為避免地區性特殊狀況導致公司(期貨經紀商)連線交易主機無法運作，且未有異地備援系統因應，公司(期貨經紀商)與期交所之連線交易主機，應建置異地備援機制。另有關公司(期貨經紀商)網路下單主機，亦宜考量建置異地備援機制。 (十)公司應擬訂營運持續計畫(含起動條件、參與人員、緊急程序、備援程序、維護時間表、教育訓練、職責說明、往來外單位之應變規劃及合約適當性等)及其必要之維護，並擬訂關鍵性業務及其衝擊影響分析，評估核心系統中斷造成之衝擊程度，並依核心系統之復原時間目標(RTO)、資料復原點目標(RPO)，作為恢復核心系統、備份備援規劃及執行復原作業之依據，再依其所屬資安分級定期辦理業務持續運作演練。公司應視演練範圍是否涉及第三方，邀請相關廠商參與演練。 (十一)公司應訂定資訊安全訊息通報機制(例如：正式之通報程序及資安事件通報聯絡人)，針對與資訊系統有關之資訊安全或服務異常事件應依「證券期貨市場資通安全事件通報應變作業注意事項」及「期貨商通報重大資安事件之範圍申報程序及其他應遵循事項」辦理，並採取適當矯正程序，留存紀錄。	10000029300 號函

編　號	作業項目	作業程序及控制重點	依據資料
CC-30000	營運持續管理	(十二)公司發生不可抗力事故，致資訊傳輸系統故障時，使用期交所雲端備援交易競價終端機系統之設備與地點，須符合期交所「期貨競價終端設備管理要點」，且應謹慎使用，並訂定管理措施，妥善管理。 (十三)公司應明確訂定分散式阻斷服務攻擊（DDoS）防禦與應變作業程序。 (十四)公司應依「證券期貨市場資通安全事件通報應變作業注意事項」之規定，於發生影響客戶權益或正常營運之資訊服務異常事件或資通安全事件時，依事件發生之時序，於「證券期貨市場資通安全通報系統」辦理通報： 1.公司於知悉事件 30 分鐘內辦理事件初步通報。若查明原因為錯誤通報，應填寫「取消通報」原因，始得辦理取消該通報。 2.公司於查明事件後，應儘速辦理事件正式通報。 3.公司於事件處理完成後，應辦理事件解除通報。 4.公司應逐日控管尚未解除通報之事件，並將尚未解除通報事件之處理情形回報期交所。 (十五)期貨經紀商平時應於公司網路下單網頁揭示其網路下單系統異常時之處理方式，以提醒期貨交易人知悉；揭示內容應包括： 1.告知其客戶於系統異常時得以何種替代方式下單。 2.系統異常時客戶與公司之緊急聯絡人與聯絡電話。 (十六)期貨經紀商於網路下單系統發生異常狀況時，通知客戶之方式，除於公司網站首頁及網路下單首頁公告異常訊息，並得以簡訊、電子郵件或其他方式通知客戶聯絡業務員改以書面、電話、電報、傳真、當面委託等人工方式下單，或採語音、專線、封閉式專屬網路等電子式委託型態下單。	

編　號	作業項目	作業程序及控制重點	依據資料
CC-30000	營運持續管理	(十七)公司應辦理下列資安防護事宜： 1.指定人員及部門統籌並協調聯繫各有關部門。 2.定期評估核心營運系統及設備，對評估結果採取適當措施，並提報董事會，以確保營運持續及作業韌性之能力。 3.於永續報告書、年報、財報或公司網站，揭露年度內公司持續核心營運系統及設備營運所需之資源及落實於年度預算或教育訓練計畫等項目。 (十八)公司應辨識風險情境，就各項風險情境當災害發生造成資訊作業異常或中斷時，擬定各系統之應變、減災或復原措施 相關作業流程。 (十九)核心系統原服務中斷時，應於可容忍時間內，由備援設備或其他方式取代並提供服務。 (二十)期貨商資訊委外作業如涉及核心資通系統與資通服務，資訊服務供應商應定期提供資通系統與資通服務之回復計畫，回復計畫可以災難復原計畫、備援演練、營運持續計畫等形式呈現。	

十一、符合性：CC-31000

編　號	作業項目	作業程序及控制重點	依據資料
CC-31000	符合性	(一)應定期(每年至少乙次)辦理資訊安全稽核作業(內部辦理或委託外部專業機構)，並應留存稽核紀錄。 (二)公司針對前開之稽核報告應限期辦理追蹤改善情形(包括稽核摘要、稽核範圍、缺失說明及改進建議等)，並留存紀錄。	一、法令規章： (一)證券暨期貨市場各服務事業建立內部控制制度處理準則第 10 條 (二)「建立期貨商資通安全檢查機制」

十二、新興科技應用：CC-32000

編　號	作業項目	作業程序及控制重點	依據資料
CC-32000	新興科技應用	(一)雲端服務： 公司應事先評估使用雲端運算服務之風險，若雲端運算服務涉及關鍵性系統、資料或服務者，應訂定雲端運算服務相關運作安全規範。 1.公司為雲端服務使用者時，應訂定雲端服務提供者之遴選機制、查核措施、備援機制、服務水準(含資訊安全防護)、復原時間及服務終止措施要求等，如有不符需求之處，需有其他補償性措施。 2.公司為雲端服務提供者時，應訂定雲端運算服務安全控管措施，應包含法律遵循、權限控管、權責歸屬及資訊安全防護等項目。如涉及敏感性資料之傳遞，應使用超文字傳輸安全協定(HTTPS)、安全檔案傳輸協定(SFTP)等加密之網路協定。 (二)社群媒體： 1.公司應訂定社群媒體相關資訊安全規範與運用社群媒體管理辦法，應包含以下內容： (1)界定可於公務用社群媒體上分享之業務相關資料。 (2)界定私人與公務用社群媒體之區別與應注意事項。 2.公司應針對開放員工使用社群媒體評估其風險程度，包含：資料外洩、社交工程、惡意程式攻擊等，並採行適當的安全控管措施。 3.公司應訂定經營官方社群媒體資訊安全規範與管理辦法，並包含以下內容： (1)應事先了解所經營之社群媒體隱私政策，並定期檢視其隱私政策之異動及評估	

編　號	作業項目	作業程序及控制重點	依據資料
CC-32000	新興科技應用	其風險。 (2)於官方網站提供連結供使用者連至公司外之社群媒體時，應出現提示視窗告知使用者該連結非公司本身之網站。 (3)對經營之社群媒體應標示期貨商名稱、聯絡方式、許可證字號、客戶申訴聯繫方式及處理窗口，以區別為官方經營之社群媒體。 (4)應建立帳號權限管理機制，對發布內容進行控管與監視，並針對不適當言論及異常事件，進行通報或處置。 (三)行動裝置： 應訂定行動裝置之資訊安全規範與管理辦法，並包含以下項目： 1.公務用行動裝置設備管理辦法： (1)公務用行動裝置管理辦法對於申請、使用、更新、繳回與審核應訂有相關規範。 (2)人員異動時，應進行重新配置或清除配置程序，以確保行動裝置環境安全性。 (3)對公務用之行動裝置應避免安裝非官方發布之行動應用程式，或僅安裝由公司列出通過檢測可安裝之行動應用程式。 (4)公務用行動裝置管理辦法內容應包含行動裝置儲存機密資料之限制與管理方式。 2.員工自攜行動裝置管理辦法，應含以下項目： (1)應要求員工自攜行動裝置使用用途。 (2)應與持有人簽署員工自攜行動裝置使用協議，含：使用限制及雙方責任等 (3)應限制內部資訊設備透過員工自攜行動裝置私接存取網際網路(Internet)之行	

編　號	作業項目	作業程序及控制重點	依據資料
CC-32000	新興科技應用	為。 (4)員工自攜行動裝置管理辦法內容應包含行動裝置儲存機密資料之限制與管理方式。 (四)物聯網： 應訂定物聯網相關資訊安全規範與管理辦法，須包含下列項目： 1.應建立物聯網設備管理清冊並至少每年更新一次，且應變更前開設備之初始密碼。 2.物聯網設備應具備安全性更新機制且定期(每年一次)更新，如存在已知弱點無法更新時，應建立補償性管控機制。 3.應關閉物聯網設備不必要之網路連線及服務，避免使用對外公開的網際網路位置。 4.如與物聯網設備供應商簽定採購合約時，其內容宜包含資訊安全相關協議，明確約定相關責任(如：服務承諾、安全性更新年限、主動通報設備已知資安漏洞並提出相關應變處置方案)，確保設備不存在已知安全性漏洞。 5.公司採購物聯網設備時，宜優先採購取得資安標章之物聯網設備。 6.公司應定期辦理物聯網設備使用及管理人員資安教育訓練。 7.公司應建立物聯網設備存取權限控管措施。 (五)遠距辦公： 1.公司應對使用遠距辦公之設備安裝資訊安全相關軟體，控管應用程式存取權限，以降低資訊外流風險。 2.公司應依業務範圍及控管權限設定居家辦公員工之系統功能權限。 3.公司應依員工執行業務內容訂定連線時段限制及相關規範。	

編　號	作業項目	作業程序及控制重點	依據資料
CC-32000	新興科技應用	4.公司應留存遠距辦公員工使用者登入系統、電腦設備操作及交易紀錄應留存軌跡。 5.公司應採多因子驗證機制（員工帳號密碼、動態密碼、一次性帳密）及建立安全的遠距網路通道，降低相關帳號密碼遭假冒或竊用之風險。 6.公司應阻擋惡意或未經授權之連線，並採用最小權限原則設定遠距帳號存取規則。 7.公司應定時更新 VPN 連線和其他遠端連結系統之安控措施。 8.公司應對客戶隱私、資料及紀錄之安全性建立保護措施。 9.公司應加強宣導資訊安全，教育遠距辦公員工應對網路風險保持警覺等資訊安全機制。 (六)深度偽造(Deepfake)： 1.使用影像視訊方式進行身分驗證時應強化驗證並搭配其他驗證因子(如上傳身分證件、手機簡訊 OTP)。 2.應定期辦理涵蓋深度偽造認知及防範議題之資訊安全教育訓練。	

十三、其他：CC-33000

編　號	作業項目	作業程序及控制重點	依據資料
CC-33000	其他	(一)資訊提供作業： 1.設置期貨行情揭示設備。 2.設置交易資訊設備。 3.設置公告欄。 4.設置期貨交易資料櫃。 5.設置資訊閱覽室(得視需要設置)。 6.因經營業務需要而為個人資料之蒐集、處理、利用或國際傳遞，應依「個人資料保護法」第二十七條第三項及「金融監督管理委員會指定非公務機關個人資料檔案安全維護辦法」規定，訂定「個人資料檔案安全維護計畫及業務終止後個人資料處理方法」。 7.應訂定適當之個人資料管理程序及個人資料安全稽核機制，除將相關機制列入內部控制及稽核項目，並應定期提出相關自我評估報告。 8.公司發生個人資料之竊取、竄改、毀損、滅失或洩漏等安全事故者，應於知悉或事實發生之日起2個營業日內函報期交所及副知主管機關。 9.對於客戶就其個人資料向公司查詢或請求閱覽或製給複本，應依「個人資料保護法」辦理。 10.於所設網站上提供期貨市場即時交易資訊，須經由與期交所簽約之資訊公司提供。 11.應定期檢查網站內對外提供之資訊，對具機密性、敏感性之資訊內容，應立即移除。	一、法令規章： (一)證券暨期貨市場各服務事業建立內部控制制度處理準則第10條 (二)「建立期貨商資通安全檢查機制」 (三)個人資料保護法 (四)個人資料保護法實施細則 (五)金融監督管理委員會指定非公務機關個人資料檔案安全維護辦法 (六)期貨競價終端設備管理要點 (七)104.8.17 台期輔字第10400024320號函 (八)96.1.17 台期資字第09600005110號函 (九)101.12.25 台期作

編　號	作業項目	作業程序及控制重點	依據資料
CC-33000	其他	12.公司之競價終端機設備，應符合期交所「期貨競價終端設備管理要點」之規定，該要點未規定者，適用主管機關、期貨公會及期交所相關之規定；另受託從事國外期貨交易，如於國內期貨交易時段外，屬國外期貨交易時段內，彈性放寬人員進出競價終端設備置放之專區者，應明定相關管制措施。 13.期貨交易資訊設備應依規定設置及使用。 14.各種重要法令規章及通知應立即張貼於公佈欄。 15.資訊閱覽室不得裝設專用競價用終端機。 16.資訊閱覽室不得限定對象且無收費行為。 17.不得於資訊閱覽室從事與客戶簽定開戶契約、接受買賣期貨之委託交割及其他類似期貨商業務行為。 18.競價終端設備委託櫃號之編碼應符合期交所「期貨商端買賣競價終端設備編號與委託書編號編列規則」之規定，並至少應保存五年(異動時亦同)。 19.使用競價終端設備連結公眾網路，應透過系統設控，禁止盤中使用競價終端設備與其他期貨商之網路下單網頁連結。	字第 10100043900 號公告